

CANONICAL PRODUCT + ENGINEERING HANDOFF

TenantProof

Focus Workbench for executed tenant-boundary evidence

Prove that Customer A cannot read or modify Customer B's data.

Product strategy, workflow, UX system, architecture, safety boundaries, commercial state, roadmap, and release protocol.

SNAPSHOT	2026-09-04
STAGE	v0.3.2 Focus Workbench request-only preview live
QUALITY	PR/main quality passed; 26-file artifact and live routes verified
COMMERCIAL	\$349 verification / \$649 verification + repair; payments closed; no customers or revenue

No customer data, credentials, real findings, testimonials, or revenue claims. Northstar CRM is fictional.

Snapshot: 2026-09-04 Product stage: v0.3.2 Focus Workbench request-only technical preview live
Commercial stage: no customer or revenue yet; static intake and payment closed Next objective:
preserve the live release, configure real operator/commercial facts, and validate one safely
authorized paid pilot before expanding the product surface

Executive summary

TenantProof is a productized Supabase/PostgreSQL tenant-isolation verification and repair service. It turns a buyer-approved authorization model into paired controls and produces redacted before/after evidence. The promise remains narrow: Prove that Customer A cannot read or modify Customer B's data.

The live v0.3.2 release replaces abstract presentation with the actual workflow. The public homepage shows a concise fictional Run preview, while `report.html` is a spacious Focus Workbench organized as Scope → Matrix → Run → Repair → Report. The interface preserves local report import, schema 1.0, filters, keyboard selection, print, contextual result limits, and an explicit unresolved state.

PR #25 was squash-merged at 8ae0bea48491b1442b1181e2c1bed21b1f2479e1. Main Pages workflow run #49 completed successfully and published the 26-file `public/` artifact at <https://undernameyet.github.io/NoNameYet/>. Public fetches on 2026-09-04 confirmed the v0.3.2 homepage, workbench, matrix, supporting routes, fictional report JSON, and fictional matrix CSV.

Product thesis

RLS presence does not encode an application's tenant and role semantics. TenantProof records those semantics as:

`actor × tenant × resource × operation × expected result`

It executes the agreed positive and negative paths in a controlled environment, records the observation, repairs the root rule when in scope, reruns the same contract, and hands off evidence with limitations. The deliverable is an engineering decision artifact—not a scanner score, badge, certification, or guarantee.

v0.3.2 public product

Homepage

- direct “verify tenant isolation before you ship” promise
- realistic fictional Workbench Run preview
- concise boundary questions, controlled method, before/after artifact, fixed prices, service boundaries, and local scope CTA
- no abstract hero illustration, stock art, generic app sidebar, or essay-length marketing wall

Focus Workbench

- compact product/review header and prominent fictional labeling
- horizontal Scope → Matrix → Run → Repair → Report rail
- Scope guardrails and agreed ceilings

- paired allow/deny Matrix contracts
- Run with 11/4/1 before and 15/0/1 after counts, combined filters, and keyboard-selectable checks
- temporary bottom evidence dock with redacted trace and remediation
- fictional reviewable SQL Repair state and retest timeline
- local JSON Report import, 2 MB maximum, browser memory only, and print

Supporting routes

- methodology/authorization
- free fictional matrix and local CSV download
- three-step local scope worksheet
- pre-commercial privacy and terms
- branded 404

Architecture and safety

V1 remains semantic HTML, two CSS layers, small vanilla JavaScript modules, and local JSON. There is no public backend, hosted account, credential vault, analytics service, payment API, arbitrary target scanner, or operational recurring monitor.

- written authorization before any real execution
- staging or a dedicated test project by default
- synthetic identities and records
- no credentials through the public site or repository
- imported report data stays in browser memory and clears on refresh
- same-origin runtime under restrictive CSP
- raw working evidence default: 14 days after accepted delivery unless a signed scope or law requires less
- Northstar CRM and every public finding are fictional

Connections, Team, Activity, Plan, hosted customer workspaces, and Continuous Verification are deferred. Continuous Verification is optional, unpriced, and must not be represented as operating until repeated paid demand and a new security/architecture decision exist.

Quality state

Local deterministic Chromium QA passed for the released implementation:

- exactly 26 public files and 8 HTML pages expected
- 16 fictional sample checks
- before: 11 pass, 4 fail, 1 unresolved
- after: 15 pass, 0 fail, 1 unresolved

- five-stage navigation, phase changes, filters, local import, row selection, dock open/close, and print hooks covered
- fictional label retained on desktop/mobile
- reduced-motion and 390 px overflow checks covered
- zero console/page errors, external runtime requests, browser persistence calls, and POST requests
- demo runner rejects live mode

The exact-head PR build passed the complete quality orchestrator with Playwright Chromium, FFmpeg, Pillow, and ReportLab. Main workflow run #49 then passed and deployed the same 26-file public-only contract. After every material source change, rerun and inspect the generated captures, walkthrough, PDF, source manifest, documentation result, and public-only bundle.

Commercial model

- Boundary Verification: \$349
- Verification + Repair: \$649
- larger, regulated, production-only, or unusually sensitive scope: manual quote
- request and qualification only; no unrestricted checkout
- invoice/escrow only after qualification, written authorization, and signed scope
- customers: 0; revenue: \$0; testimonials: 0; published real findings: 0

Payment stays closed until a real contracting party, jurisdiction, owned business contact/intake and deletion route, launch-state legal copy, processor/tax/refund position, security contact, and delivery capacity are verified.

Continuation plan

- 1 Preserve the v0.3.2 request-only preview and its public-only deployment boundary.
- 2 Keep state: `preview`, `paymentMode: closed`, and all fictional labels until verified commercial facts exist.
- 3 Configure the real contracting identity, jurisdiction, owned HTTPS intake/deletion route, security contact, delivery capacity, processor/tax/refund position, and launch-state legal copy.
- 4 Run `npm run release:strict` only after those blockers are truthfully resolved; do not weaken the gate.
- 5 Prefer one safely authorized paid pilot over speculative workspace, billing, connection, or recurring-monitoring features.
- 6 For any product change, use a focused branch, exact-head CI, changed-file/secret review, generated-artifact reconciliation, and live route verification after merge.
- 7 Keep customer evidence, credentials, authorization records, and engagement workspaces outside this public repository.

Design direction to preserve

- purpose-built engineering workbench, not generic SaaS chrome
- one workflow stage at a time
- concise copy, authentic product details, generous working space
- horizontal stage rail; no permanent sidebar or inspector
- temporary evidence dock only after selection
- warm paper, graphite/ink structure, restrained product accent, semantic result colors
- no abstract tenant circles, jagged seams, decorative boundary paths, hacker clichés, or “Watch the boundary hold” concept

Historical context

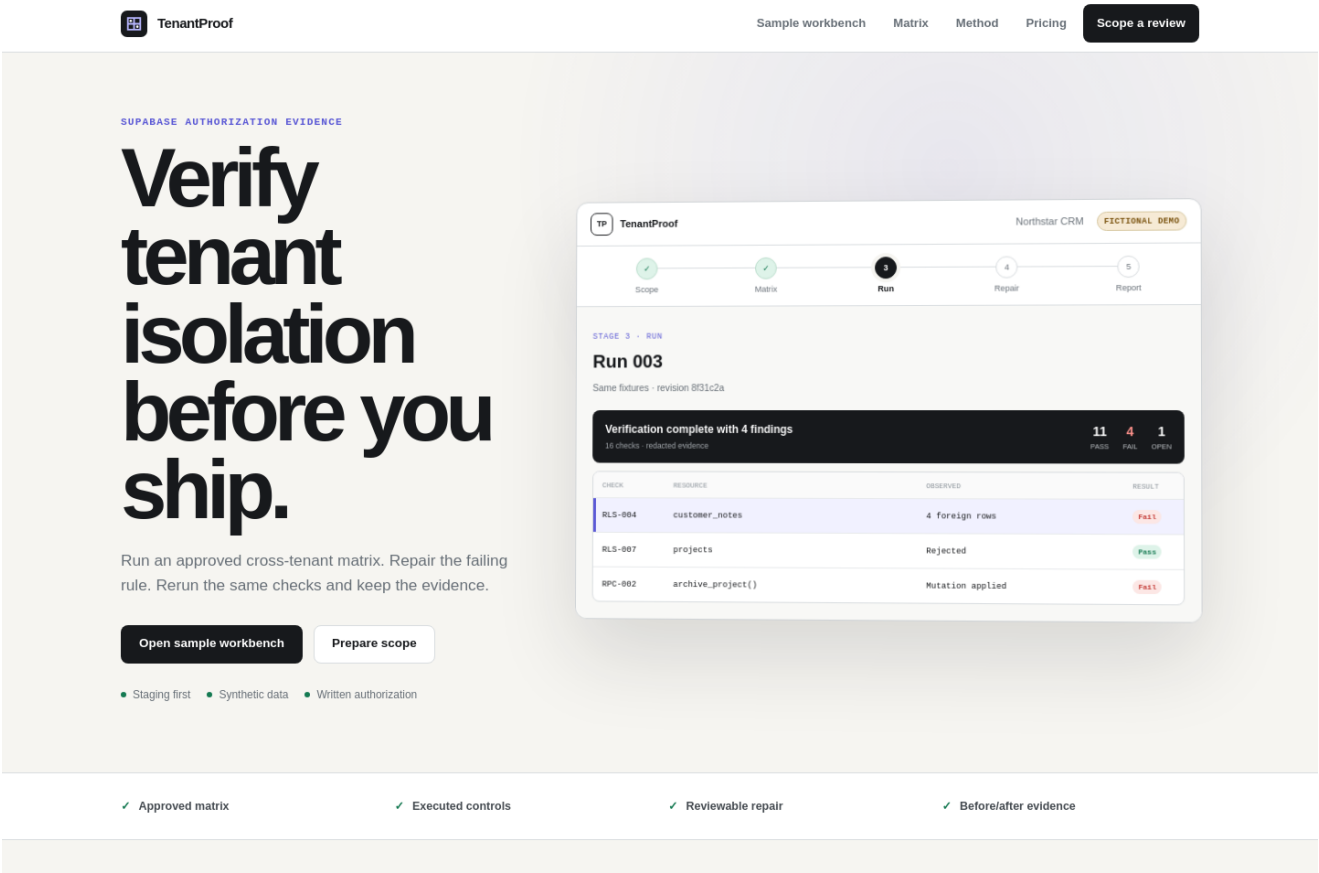
RebuttalKit, Stay5, the App Store screenshot service/ClearCal proposal, and Relay migration concepts are frozen or rejected. Do not revive them as TenantProof proof, merge their positioning into this product, or use their artifacts as customer evidence.

Handoff integrity

This repository records product strategy, implementation, decisions, limitations, and operational safeguards. It contains no customer secrets, production credentials, private evidence, or fabricated work. Future changes must preserve that standard and the public-only deploy boundary.

Visual product reference

Generated from the fictional public product; no customer evidence is included.



Product-first homepage — real Run-stage preview and primary actions

TP

TenantProof

Northstar CRM

FICTIONAL DEMO

Review TP-DEMO-0830

Method

Scope a review

VERIFICATION + REPAIR

Northstar CRM

TP-DEMO-0830 • Fictional staging demo

1

2

3

4

5

Scope

Matrix

Run

Repair

Report

FICTIONAL DEMO

Print

STAGE 3 • RUN

Before repair

After repair

Run 003

Same fixtures, same approved matrix, revision 8f31c2a.

Verification evidence

16 TOTAL11 PASS4 FAIL1 OPEN

18 checks • Aug 30, 2026

Search checks

All actors

All areas

All operations

All results

RESOURCE	ACTOR	OPERATION	RESULT
customer_notes Table	member	read	FAIL
customer_notes Table	member	update	FAIL
accounts Table	manager	read	PASS
projects Table	member	insert	PASS
projects Table	member	delete	PASS

16 shown

Select a row to inspect redacted evidence.

Northstar CRM and all findings are fictional. Local report files stay in browser memory.

Return to TenantProof

Focus Workbench Run — filters, counts, and evidence table

TenantProof

TenantProof / Scope a review

PRIVATE LOCAL WORKSHEET

Describe the boundary. Keep the secrets.

This pre-launch form creates a review brief in your browser. It does not transmit the contents or authorize testing.

Package

Application

Private brief

STEP 1 OF 3

Choose the starting scope

Final scope is confirmed before payment or access.

Boundary Verification · \$349

Up to 12 tables, three roles, executed matrix, findings, and one retest.

Verification + Repair · \$649

Up to 25 tables, selected functions and storage, patches, regression checks, and one retest.

Review pricing

Describe application

NEVER PUT THESE IN THE BRIEF

Credentials belong in a separate, approved access process.

- Supabase service-role keys or database passwords
- Production customer records or database exports
- Personal information not necessary for scoping
- Credentials for GitHub, hosting, billing, or analytics
- A third party's target without written authorization

TenantProof

Evidence-driven tenant-boundary verification and repair for Supabase applications.

PRODUCT

Sample report

Methodology

Pricing

TRUST

Privacy

Terms

START

Scope a review

© 2026 TenantProof. Pre-launch preview.

This form does not transmit data.

Mobile local scope worksheet — non-sensitive and non-submitting

TenantProof • canonical handoff • v0.3.2

8

TP

TenantProof

Northstar CRM

FICTIONAL DEMO

Review TP-DEMO-0830

Method

Scope a review

VERIFICATION + REPAIR

Northstar CRM

TP-DEMO-0830 • Fictional staging demo

1

2

3

4

5

Scope

Matrix

Run

Repair

Report

FICTIONAL DEMO

Print

STAGE 2 • MATRIX

Open free matrix

Paired boundary contracts

Every allowed path is paired with a denied tenant or role control.

CONTRACT 01

Member reads customer notes

ALLOW

Own tenant

Return the member's assigned notes.

DENY

Comparison tenant

Return zero foreign rows.

SELECT • member • customer_notes

CONTRACT 02

Manager archives a project

ALLOW

Assigned project

Apply the archive transition.

DENY

Foreign project

Reject the RPC mutation.

RPC • manager • archive_project()

CONTRACT 03

Member updates a project

ALLOW

Owned record

Accept the intended field update.

DENY

Tenant reassignment

Reject proposed foreign tenant ID.

UPDATE • member • projects

CONTRACT 04

Member lists customer files

ALLOW

Own prefix

List the permitted object path.

OPEN

Foreign prefix

Storage comparison remains untested.

LIST • member • customer-files

Northstar CRM and all findings are fictional. Local report files stay in browser memory.

Return to TenantProof

Focus Workbench Matrix — paired allow and deny contracts

TP

TenantProof

A green RLS badge is not proof.

Executed tenant-boundary evidence for Supabase SaaS.

BOUNDARY MATRIX

16

CHECKS

4

FAILED

11

BLOCKED

customer_notes

FAIL

projects

PASS

archive_project()

FAIL

customer-files

PASS

1200×630 social-preview asset

TenantProof • canonical handoff • v0.3.2

9

Canonical source index

The PDF is a snapshot. Markdown and JSON remain editable source of truth.

- AGENTS.md
- handoff/HANDOFF_REPORT.md
- handoff/CURRENT_STATE.json
- handoff/PRODUCT_SPEC.md
- handoff/PAGE_AND_SECTION_SPECS.md
- handoff/UX_DESIGN_SYSTEM.md
- handoff/TECHNICAL_ARCHITECTURE.md
- handoff/FEATURE_AND_FUNCTION_INVENTORY.md
- handoff/REPORT_ENGINE_SPEC.md
- handoff/SECURITY_PRIVACY_AND_SAFETY.md
- handoff/OPERATIONS_AND_INTAKE.md
- handoff/COMMERCIAL_AND_PAYMENTS.md
- handoff/GTM_AND_VALIDATION.md
- handoff/ROADMAP_V1_V2_V3.md
- handoff/DECISION_LOG.md
- handoff/REJECTED_IDEAS_AND_LEARNINGS.md
- handoff/QUALITY_GATES.md
- handoff/RELEASE_AND_REPOSITORY.md
- handoff/ASSET_MANIFEST.md
- handoff/AI_CONTINUATION.md

Continuation rule

Read AGENTS.md first, validate CURRENT_STATE.json against GitHub, run the complete quality gate, and update the handoff whenever behavior or decisions change.